

THM : Merry Clickmas

```
root@ip-10-49-162-9:~# cd /Rooms/AoC2025/Day02
bash: cd: /Rooms/AoC2025/Day02: No such file or directory
root@ip-10-49-162-9:~# cd ~/Rooms/AoC2025/Day02
root@ip-10-49-162-9:~/Rooms/AoC2025/Day02# ls
index.html  server.py
root@ip-10-49-162-9:~/Rooms/AoC2025/Day02# ./server.py
Starting server on http://0.0.0.0:8000
```

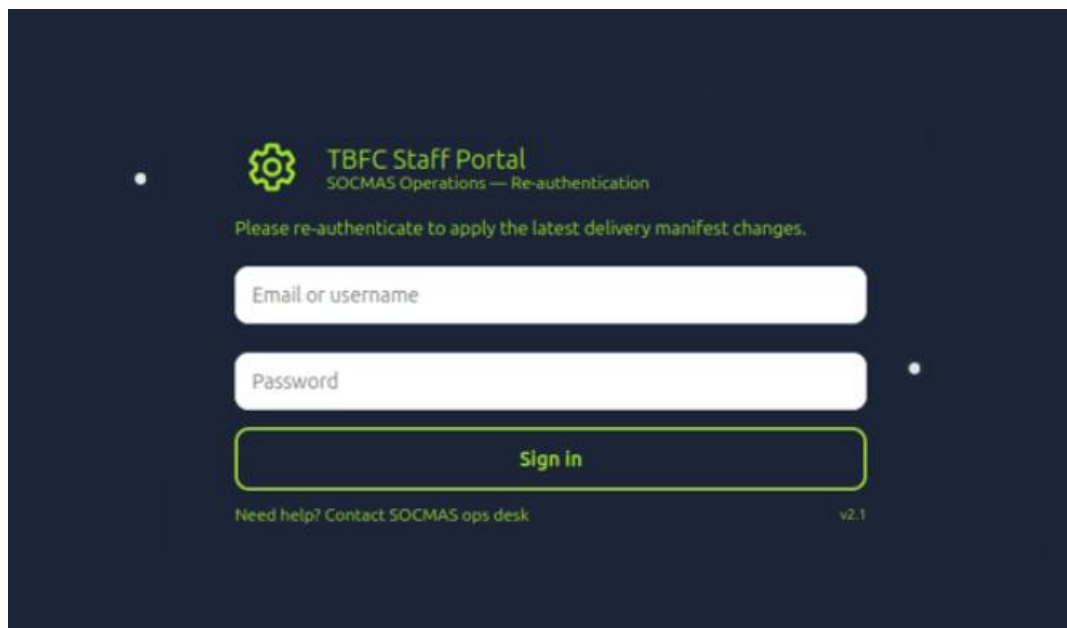
cd ~/Rooms/AoC2025/Day02

ls

Navigate to the Day02 directory. Inside, you will find the index.html and server.py files. To launch the Python HTTP server, run the following command.

./server.py

A basic Python HTTP server hosts the landing page (index.html). By binding to all network interfaces (0.0.0.0) on port 8000, the page becomes accessible to any device with network connectivity to the host system.



This configuration is frequently utilized during simulated red-team exercises due to its minimal setup requirements. It provides complete control over the hosted content, enabling the delivery of specific payloads or credential-capture interfaces.

```
MM      .. 888.MMMMMM      .      .M.
MM      888.MMMMMMMMMMMMMM      M
MM      888.MMMMMMMMMMMMMM.      M
MM      888.      NMMMMM.      .M
M.      888.MMMMMMMMMMMMMM.      ZM
NM.      888.MMMMMMMMMMMMMM      M:
.M+      .....      MM.
.MM.      .MM.      .MD
MM      .MM      .MM
$MM      .MM.      .MM.
,MM?      .MMM
,MMMMMMMMMMMMM
https://www.trustedsec.com

[—]      The Social-Engineer Toolkit (SET)      [—]
[—]      Created by: David Kennedy (ReL1K)      [—]
          Version: 8.0.3
          Codename: 'Maverick'
[—]      Follow us on Twitter: @TrustedSec      [—]
[—]      Follow me on Twitter: @HackingDave      [—]
[—]      Homepage: https://www.trustedsec.com      [—]
Welcome to the Social-Engineer Toolkit (SET).
The one stop shop for all of your SE needs.

The Social-Engineer Toolkit is a product of TrustedSec.

Visit: https://www.trustedsec.com

It's easy to update using the PenTesters Framework! (PTF)
Visit https://github.com/trustedsec/ptf to update all your too

Select from the menu:

1) Social-Engineering Attacks
2) Penetration Testing (Fast-Track)
3) Third Party Modules
4) Update the Social-Engineer Toolkit
5) Update SET configuration
6) Help, Credits, and About

99) Exit the Social-Engineer Toolkit
```

Next, open a separate terminal window and launch the Social Engineer Toolkit (SET) using the following command.

```
sudo setoolkit
```

From the main menu, select option **1** for Social Engineering Attacks.

Please update SET to the latest before submitting any git issues.

Select from the menu:

- 1) Spear-Phishing Attack Vectors
- 2) Website Attack Vectors
- 3) Infectious Media Generator
- 4) Create a Payload and Listener
- 5) Mass Mailer Attack
- 6) Arduino-Based Attack Vector
- 7) Wireless Access Point Attack Vector
- 8) QRCode Generator Attack Vector
- 9) Powershell Attack Vectors
- 10) Third Party Modules

99) Return back to the main menu.

set> 5

Social Engineer Toolkit Mass E-Mailer

There are two options on the mass e-mailer, the first would be to send an email to one individual person. The second option will allow you to import a list and send it to as many people as you want within that list.

What do you want to do:

1. E-Mail Attack Single Email Address
2. E-Mail Attack Mass Mailer

99. Return to main menu.

set:mailer>1

Do you want to use a predefined template or craft a one time email template.

1. Pre-Defined Template
2. One-Time Use Email Template

From the subsequent menu, option 5 is chosen to initiate the Mass Mailer Attack configuration. The interface then prompts for the target scope, where option 1 is selected for a single email address targeting strategy. Finally, option 2 is applied to configure a One-Time Use Email Template.

```

set:mailer>1

Do you want to use a predefined template or craft
a one time email template.

1. Pre-Defined Template
2. One-Time Use Email Template

set:phishing>2
set:phishing> Subject of the email: Shipping Schedule Changes
set:phishing> Send the message as html or plain? 'h' or 'p' [p]: p
[!] IMPORTANT: When finished, type END (all capital) then hit {return} on a new line.
set:phishing> Enter the body of the message, type END (capitals) when finished: Dear Valued Customer,

Your recent shipment via Flying Deer has been delayed due to an incorrect shipping address.

To avoid further delays and reschedule your delivery, please verify your address immediately:Next line of the body:
Next line of the body: Next line of the body: Next line of the body: http://10.65.118:8000
Next line of the body: Once verified, your package will be shipped out within 24 hours.

We apologize for the inconvenience.

Thank you for choosing Flying Deer Shipping.

Regards,
Flying Deer Support TeamNext line of the body: Next line of the body: Next line of the body: Next line of the body:
Next line of the body: Next line of the body: Next line of the body: END
Next line of the body: END
set:phishing> Send email to: factory@wareville.thm

1. Use a gmail Account for your email attack.
2. Use your own server or open relay

set:phishing>2
set:phishing> From address (ex: moo@example.com): updates@flyingdeer.thm
set:phishing> The FROM NAME the user will see: Flying Deer
set:phishing> Username for open-relay [blank]:
Password for open-relay [blank]:
set:phishing> SMTP email server address (ex. smtp.youremailserveryouown.com): 10.65.187.207
set:phishing> Port number for the SMTP server [25]:
set:phishing> Flag this message/s as high priority? [yes|no]: no

```

Next, fill in the required fields when prompted, including the email Subject and the Message Body.

set:phishing> Subject of email: Shipping Schedule Changes

The wizard then requests the message format configuration. Entering **p** selects the Plain Text option, after which the interface prompts for the input of the message body content.

Dear Valued Customer,

Your recent shipment via Flying Deer has been delayed due to an incorrect shipping address.

To avoid further delays and reschedule your delivery, please verify your address immediately:

http://10.65.118:8000

Once verified, your package will be shipped out within 24 hours.

we apologized for the inconvenience.

Thank you for choosing Flying Deer Shipping.

Regards,

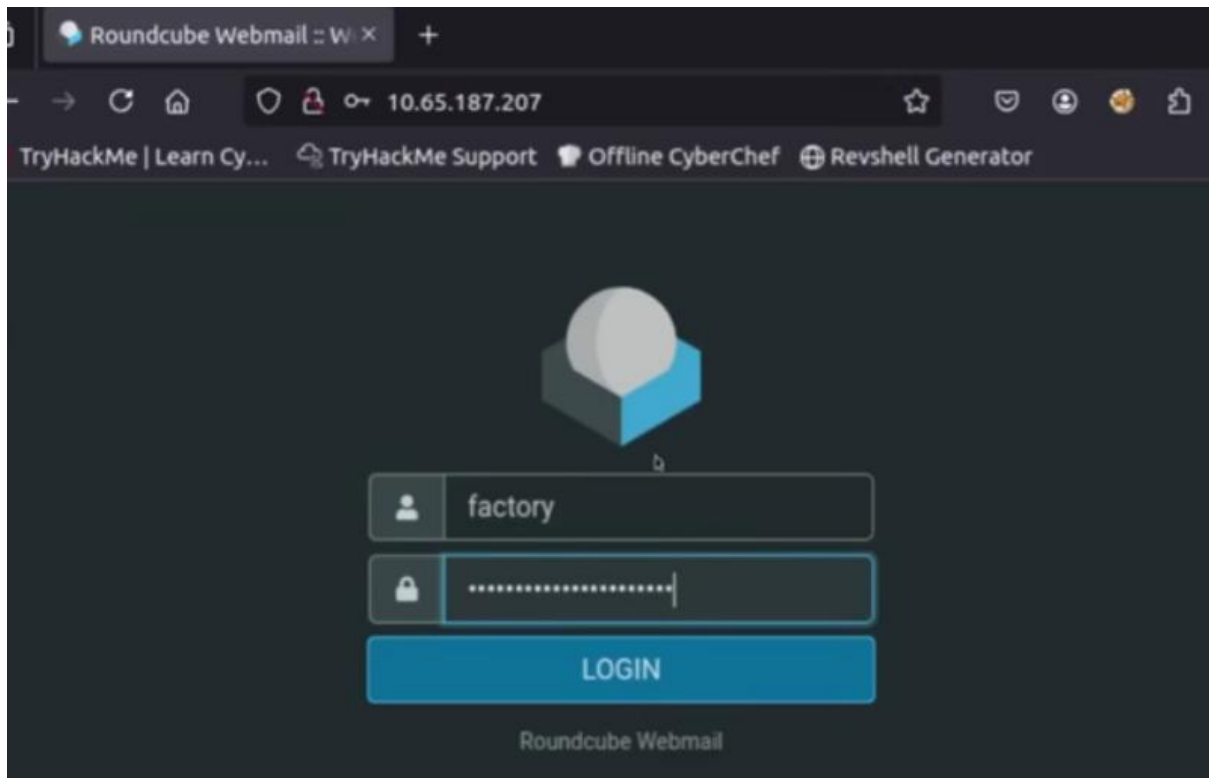
Flying Deer Support

END

Once the configuration is complete, the email is dispatched to the target mail server. The terminal remains active to monitor for incoming connections or simulated credential submissions from the target system.

```
root@ip-10-65-118-60:~/Rooms/AoC2025/Day02#  
./server.py  
Starting server on http://0.0.0.0:8000  
10.65.187.207 - - [30/Nov/2025 21:36:01] "GET / HTTP/1.1" 200 -  
[2025-11-30 21:36:01] Captured -> username:  
admin password: unranked-wisdom-anthem  
from: 10.65.187.207  
10.65.187.207 - - [30/Nov/2025 21:36:01] "POST /submit HTTP/1.1" 303 -  
10.65.187.207 - - [30/Nov/2025 21:36:01] "GET / HTTP/1.1" 200 -
```

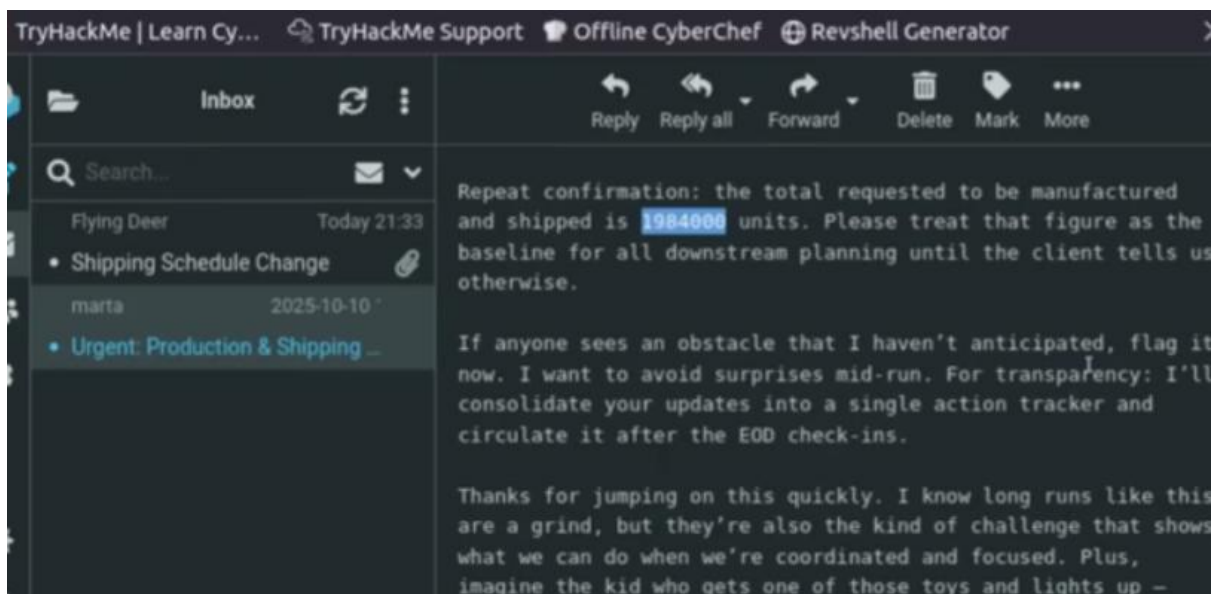
The exercise successfully captured the credentials username: admin and password: unranked-wisdom-anthem. These credentials can be utilized to verify access controls on the target organization's web portal.



we go to target's company website on <http://10.65.187.207>

with this credentials:

username: factory



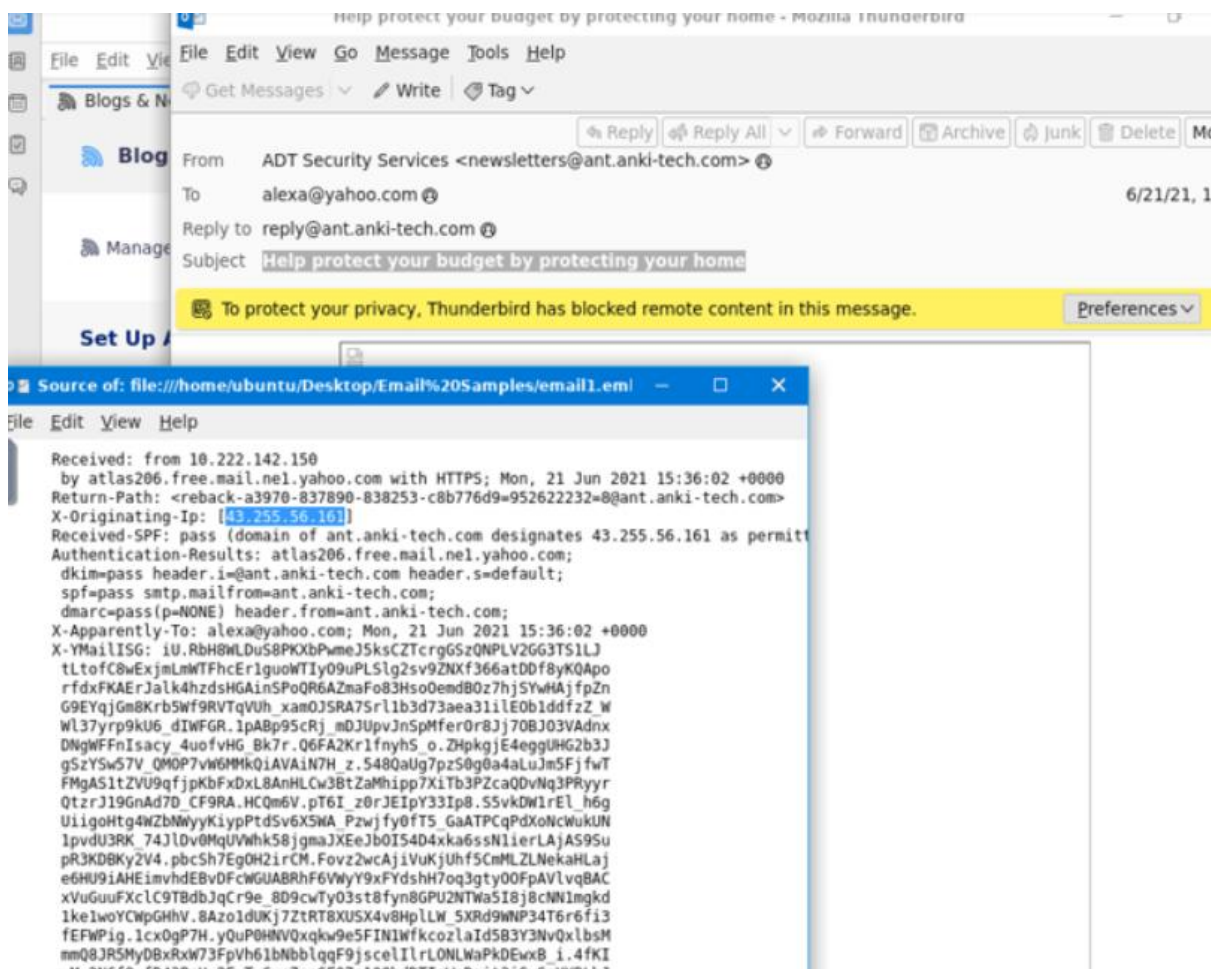
Following the successful credential capture, access was established to the target email account. Review of the inbox confirmed receipt of the simulated phishing email and revealed internal operational correspondence regarding a manufacturing request for 1,984,000 units.

THM : Phishing Analysis Fundamental

Spam and phishing continue to represent the primary social engineering vectors targeting modern organizations. While spam generally presents a lower risk profile, phishing tactics actively deceive personnel into exposing sensitive credentials or executing malicious payloads. A single compromised interaction with an unauthorized link or attachment can establish an initial foothold within the network, potentially leading to widespread systemic impact.

the domain for hatsalesman@tryhatme.com is *tryhatme.com*

1. *SMTP* is used for sending an email from a client to a mail server.
2. *DNS* is used to look up the recipient domain's mail server
3. *IMAP* is used to Sync emails across devices



An alternative method for acquiring comprehensive email header data involves analyzing the raw message source. Accessing the email source displays the full, unformatted message data including all header fields, plain text or HTML bodies, and technical details omitted from the standard inbox view. By navigating to the View menu and selecting Message Source, we verified that the complete subject line for email1.eml is *'Help protect your budget by protecting your home'*. Additionally, the X-Originating-Ip header explicitly identifies the originating IP address as 43.255.56.161.

```
File Edit Search View Document Help
-----0917b1a36408bb427c44063070707099
Content-Type: application/pdf; filename="zmqpalgh.pdf"; name="zmqpalgh.pdf"
Content-Transfer-Encoding: base64
Content-Disposition: attachment; filename="zmqpalgh.pdf"; name="zmqpalgh.pdf"

JVBERi0xLjYnJElz9MNCjE0IDAgb2JqDTw8L0xpbmVhcmcl6ZWQgMS9MIDM1Mjc3L08gMTYvRSAz
MDE4MS90IDEvVCAzNDk3My9IIFsgNDU3IDE1NF0+Pg1lbmRvYmoNICAgICAgICAgICAgICAgICAg
DQoyMSAwIG9iag08PC9EZWNvZGVQYXJtczw8L0NvbHVtbnMgNC9QcmVkaWNoY3IgMTI+Pi9GaWx0
ZXIvRmxdGVEZWNvZGUvSURbPDM2Qzc0RjRkxRDgzMDdENDQ4MTQ5MjQ5OERFMjVVG0RCPjxFREMx
QTYwN0I0NzJFQTQ5QUVDNTc3NUE0MTRENDM5Qz5dL0luZGV4WzE0IDEuXSV9JmZvIDEzIDAgUi9M
ZW5ndGggNTQvUHJldiAzNDk3NC9Sb290IDE1IDAgUi9TaXplIDI1L1R5cGUvWFJlZi9XWzEgMiAx
XT4+c3RyZWFTDQpo3mJiZBBgYGJgCgYSDFOABOMuEHcRiGUNJPLuAYkeDgYmRoa5ICUMjEz/GXf8
BwgwAJk5B+INCmVuZHN0cmVhbQ1lbmRvYmoNc3RhcnR4cmVmDQowDQolJUUVPRg0KICAgICAgICAN
CjI0IDAgb2JqDTw8L0MgNzVhbmRmLsdGVyL0ZsYXRlRGVjb2RlL0kgOTUvTGvUz3RoIDcwL1MgMzg+
PnN0cmVhbQ0KaNSiYGBgZWBgimUAgqJ3DKiAEYhZGDgkMVYoZiBYRcDPwMD8wIwvks04g+gykuf
QmjGKrgGFgaG9haoqBRAGAEauiI5Q0KZW5kc3RyZWFTDwvUzG9iag0xNSAwIG9iag08PC9MYW5n
KP7/AEUATgAtAFUAUykvTwFya0luZm88PC9NYXJrZWQgdHJlZT4+L01ldGFkYXRhIDIgMCSL1Bh
Z2VMYXlvdXQvT25lQ29sdW1uL1BhZ2VzIDeYIDAgUi9TdHJlY3RUcmVlUm9vdCA2IDAgUi9UeXB1
L0NhdGFsb2c+Pg1lbmRvYmoNMTYgMCSvYmoNPDwvQ29udGVudHMgMTggMCSL0Ny3BCb3hbMC4w
IDAuMCA2MTIuMCA30TIuMF0vTWVkaWFCb3hbMC4wIDAuMCA2MTIuMCA30TIuMF0vUGFyZW50IDEy
IDAgUi9SZNvdXJjZXM8PC9Gb250PDwvVFQwIDIZIDAgUj4+Pj4vUm90YXRlIDAvU3RydWN0UGFy
ZW50cyAwL1RhYnMvUy9UeXB1L1BhZ2U+Pg1lbmRvYmoNMTcgMCSvYmoNPDwvRmLsdGVyL0ZsYXRl
RGVjb2RlL0ZpcnN0IDEyL0xlbmd0aCAzMjVtYyAyL1R5cGUvT2JqU3RtPj5zdHJlYW0NCmJepFFb
a8IwGP0r3+PGkFya9AJSSG5LA3Ewqw7Eh1hDG2hTSSPMf780dg7GnjYSAjnf4Vz4KAUMNHCXwnSK
Zn0ptQWCaYjm4vQsVVVbCA0KHuV1NAKIRXkjqh4cmnfazln3sZtwHPgZEMqwf9j7a55a1Vzu5qJR
B6Pur5hqpCMmzvRNA0vRSpS9Fov15mFkenx1jbrljZadaUXjoe01EsMYvVhHLWe6aiRgtLKy3UCM
```

Following the same procedure for email2.txt, the raw source was accessed via View > Message Source. Examination of the MIME content headers revealed an attached file with a specified Content-Type of application/pdf. The corresponding metadata identifies the filename of this PDF attachment as zmqpalgh.pdf.


```
File Edit Search View Document Help
-----0917b1a36408bb427c44063070707099
Content-Type: application/pdf; filename="zmqpalgh.pdf"; name="zmqpalgh.pdf"
Content-Transfer-Encoding: base64
Content-Disposition: attachment; filename="zmqpalgh.pdf"; name="zmqpalgh.pdf"

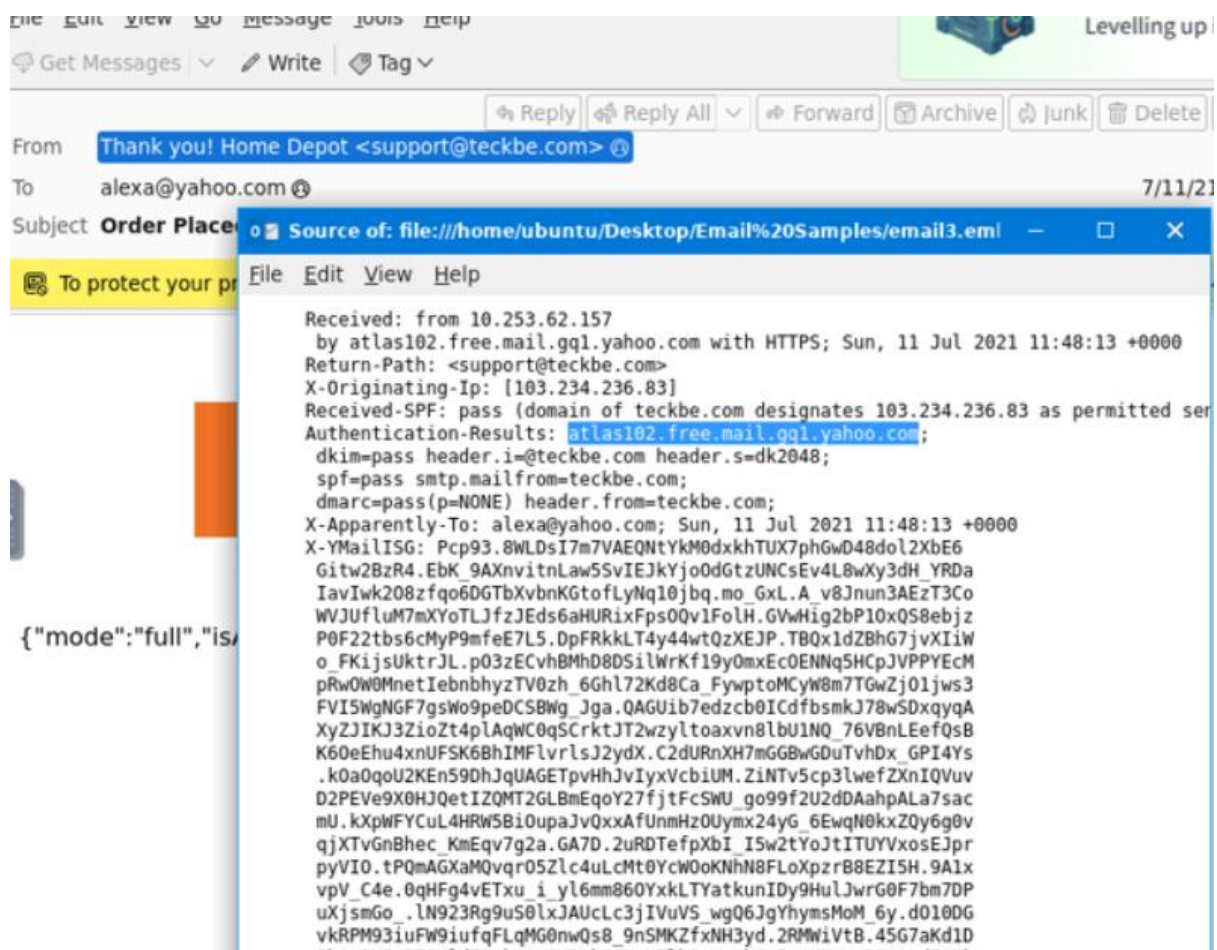
JVBERi0xLjYnJelJz9MNCjE0IDAgb2JqDw8L0xpbmVhcm16ZWQgMS9MIDM1Mjc3L08gMTYvRSAz
MDE4MS90IDEvVCAzNDk3My9IIFsgNDU3IDE1NF0+Pg1lbmRvYmoNICAgICAgICAgICAgICAg
0QoyMSAwIG9iag08PC9EZWNvZGV0YXJtczw8L0NvbHVtbnMgNC9QcmVkaWNoY3IgMTI+Pi9GaWx0
ZXIvRmxhdGVEZWVvZGUvSURbPDM2Qzc0RjKxRDgzMDdENDQ4MTQ5MjQ50ERFMjVGQ0RCPjxFREx
0TYwN0I0NzJFQTQ5QUVDNTc3NUE0MTRENDM5Qz5dL0luZGV4WzE0IDE1L1R5cGUvWFJlZi9XWzEgMiAx
ZW5ndGggNTQvUHJldiAzNDk3NC9Sb290IDE1IDAgUi9TaXplIDI1L1R5cGUvWFJlZi9XWzEgMiAx
X4+c3RyZWFTDQpo3mJiZBBgYgJgCgYSDF0AB0MuEHCRiGUNJPLuAYkeDgYmRoa5ICUMjEz/GXf8
8wgwAJk5B+INcmVuZHN0cmVhbQ1lbmRvYmoNC3RhcnR4cmVmDQowDQo1JUVPRg0KICAgICAgICAN
CjI0IDAgb2JqDw8L0MgNzMrMlSDGVyL0ZsYXRlRGVjb2RlL0kg0TUvTGvUz3RoIDcwL1MgMzg+
PnN0cmVhbQ0KaNSiYGBgZWBgimUAgqJ3DKiAEYhZGDgkMVYoZiBYRCDPwMD8wIwvks04g+gykuf
0mjGKrgGFgaG9haoqBRAGAEaAII5Q0KZW5kc3RyZWFTDwVvZGV4WzE0IDE1L1R5cGUvWFJlZi9XWzEg
KP7/AEUATGAtAFUAUykvTwFya0luZm88PC9NYXJrZWQgdHJlZT4+L01ldGFkYXRhIDIgMCSL1Bh
Z2VMYXlvdXQvT25lQ29sdW1uL1BhZ2VzIDEyIDAgUi9TdHJlY3RUcmVlUm9vdCA2IDAgUi9UeXB1
L0NhZGFsb2c+Pg1lbmRvYmoNMTYgMCSvYmoNPdWvQ29udGVudHMgMTggMCSL0Ny3BCb3hbMC4w
IDAuMCA2MTIuMCA30TIuMF0vTwVkaWFCb3hbMC4wIDAuMCA2MTIuMCA30TIuMF0vUGFyZW50IDEy
IDAgUi9SZNvdXJjZXN0PC9Gb250PDwvVFQwIDIzIDAgUj4+Pj4vUm90YXRlIDAvU3RydWNoUGFy
ZW50cyAwL1RhYnMvUy9UeXB1L1BhZ2U+Pg1lbmRvYmoNMTcgMCSvYmoNPdWvRmlsdGVyL0ZsYXRl
RGVjb2RlL0ZpcnN0IDEyL0xlbmd0aCAzMjMvTiAyL1R5cGUvT2JqU3RtPj5zdHJlYWNoNCmJepFFb
8IwGP0r3+PGkFya9AJSSG5LA3EwqW7Eh1hDG2hTSSPMf780dg7GnjYSAjnf4Vz4KAUMNHCXwnSK
Zn0ptQwCaYjm4vQsVVVbCAOKHuV1NAKIRXkjgh4cmnfazln3sZtwHPgZEMqwF9j7a55a1Vzu5qJR
86Pur5hqpCMmzvRNA0vRSpS9Fov15mFkenx1jbr1jZadaUXjoe01EsMYvVhHLWe6aiRgtLKy3UCM
```

To extract the flag from the email header, copy the complete Base64-encoded string for decoding.

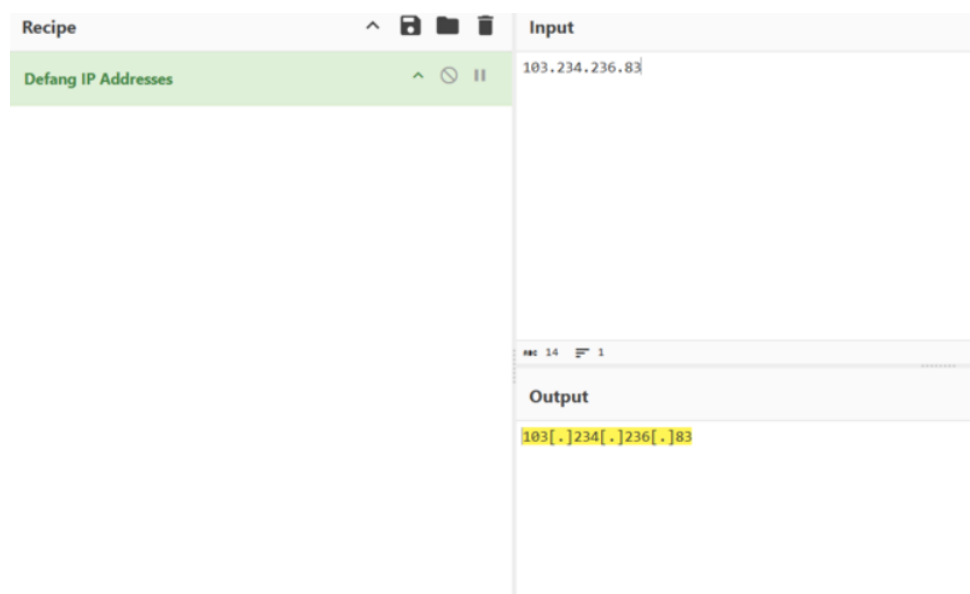
[illegible]

THM(BENIGN_PDF_ATTACHMENT)

Next, decode the extracted Base64 string into its original PDF format using a decoding utility to reveal the hidden flag.



Reviewing the raw source of email3.eml via View > Message Source reveals that the attacker spoofed the branding of Home Depot to conduct the phishing attempt. Closer inspection of the transport headers shows the actual sender address is support@teckbe.com. Additionally, the Authentication-Results header indicates that the generating mail server for this message was atlas102.free.mail.gq1.yahoo.com.



To prevent accidental navigation during analysis, all hyperlinks, domains, and IP addresses within security documentation must be defanged. This practice sanitizes actionable indicators such as substituting brackets into URLs or network addresses to ensure they cannot be inadvertently clicked or resolved. For example, a standard malicious URL is neutralized from

http://www.suspiciousdomain.com to hxxp[://]www[.]suspiciousdomain[.]com. Utilizing the CyberChef platform to defang the identified X-Originating-IP yields the safe indicator format: 103.234.236.83.